AUDITORIA TECNICA COMPLETA

KiteOS ERP

Relatorio de Seguranca, Conformidade Fiscal e Pre-Producao

Data	Versao	Classificacao
11/06/2026	**1.0**	**CONFIDENCIAL**

Sumario

1. Sumario Executivo ..... Pag. 3

2. Matriz de Vulnerabilidades ..... Pag. 5

2.1 Vulnerabilidades CRITICAL ..... Pag. 5

2.2 Vulnerabilidades HIGH ..... Pag. 6

2.3 Vulnerabilidades MEDIUM ..... Pag. 8

2.4 Vulnerabilidades LOW ..... Pag. 9

3. Auditoria de Seguranca - OWASP Top 10 ..... Pag. 10

4. Conformidade Fiscal ..... Pag. 12

5. Isolamento Multi-Tenant ..... Pag. 13

6. Correcoes de Codigo Aplicadas ..... Pag. 14

7. Checklist Pre-Producao ..... Pag. 16

8. Roadmap de Correcoes ..... Pag. 17

1. Sumario Executivo

Este relatorio apresenta os resultados da auditoria tecnica completa do sistema KiteOS ERP, abrangendo seguranca da informacao, conformidade fiscal e prontidao para producao. A auditoria foi conduzida utilizando metodologia baseada no OWASP Top 10 (2021), analise estatica de codigo-fonte, testes de penetracao limitados e revisao de conformidade fiscal conforme legislacao brasileira vigente.

A auditoria identificou **79 vulnerabilidades** no total, das quais **18 sao criticas** e **33 sao de alta severidade**. Apenas **14 das 79 vulnerabilidades foram corrigidas** durante o periodo da auditoria, resultando em uma taxa de correcao de apenas 17.7%. As vulnerabilidades restantes exigem correcao imediata antes de qualquer deploy em ambiente de producao.

VEREDITO GERAL: REPROVADO PARA PRODUCAO

Pontuacao por Dimensao

32/100	45/100	55/100	60/100
Security Score	Fiscal Score	Architecture Score	Performance Score

Security Score: 32/100 - CRITICO

Nao apto para producao. Multiplas vulnerabilidades criticas na autenticacao (JWT hardcoded, SHA-256 para senhas), autorizacao (sem RBAC, endpoints admin sem auth) e integridade de dados (webhook sem assinatura, XML sem verificacao). A superficie de ataque e significativamente ampla, permitindo desde acesso nao autorizado ate manipulacao financeira direta.

Fiscal Score: 45/100 - ALTO RISCO

Multiplas questoes de conformidade fiscal. O SPED Fiscal nao pode ser enviado devido a erros no Bloco 9 e nos registros 0200 e C990. Calculos de ISSQN/INSS para Simples Nacional estao incorretos. A ausencia de verificacao de assinatura digital em NF-e importadas representa risco legal grave, incluindo possivel caracterizacao de crime fiscal.

Architecture Score: 55/100 - MEDIO

Necessita melhoria substancial. O modelo multi-tenant tem falhas de isolamento (TaxRule compartilhado). O uso de Float para valores monetarios (60+ campos) pode causar discrepancias financeiras. A ausencia de RBAC permite que qualquer funcionario execute acoes administrativas. O sistema de assinaturas nao tem enforcement no server-side.

Performance Score: 60/100 - MEDIO

Aceitavel para escala atual, mas com limitacoes. O rate limiter em memoria e perdido a cada restart. Nao ha cache distribuido para sessoes ou dados frequentes. As consultas ao banco de dados nao possuem indices otimizados para os padroes de acesso mais comuns. A ausencia de paginacao em algumas rotas pode causar problemas com volumes maiores de dados.

Estatisticas de Vulnerabilidades

Severidade	Quantidade	Corrigidas	Pendentes	Taxa Correcao
CRITICAL	**18**	10	**8**	56%

HIGH	33	4	29	12%
MEDIUM	19	0	19	0%
LOW	9	0	9	0%
TOTAL	79	14	65	17.7%

Metricas-Chave

Total de vulnerabilidades encontradas: 79 (18 CRITICAL, 33 HIGH, 19 MEDIUM, 9 LOW)

Arquivos corrigidos durante a auditoria: 8 (7 arquivos + 1 middleware)

Cobertura de testes estimada: ~15% (Meta para producao: 85%)

Rotas sem autenticacao identificadas: 5 (4 corrigidas, 1 pendente)

Campos Float em valores monetarios: 60+ no schema Prisma

Endpoints sem RBAC: Todos os endpoints (implementacao pendente)

Modulos com risco fiscal critico: SPED, NF-e, NFS-e, ISSQN/INSS

Risco financeiro total estimado: R$ 25.500 a R$ 305.000 em multas potenciais

2. Matriz de Vulnerabilidades

A tabela abaixo lista todas as 79 vulnerabilidades identificadas durante a auditoria do KiteOS ERP, organizadas por severidade (CRITICAL, HIGH, MEDIUM, LOW). Cada vulnerabilidade e classificada com um identificador unico, o modulo afetado, a descricao do problema e o status atual de correcao. Vulnerabilidades CRITICAL e HIGH devem ser obrigatoriamente resolvidas antes de qualquer deploy em ambiente de producao.

2.1 Vulnerabilidades CRITICAL (18 encontradas, 10 corrigidas, 8 pendentes)

Vulnerabilidades criticas representam risco imediato de comprometimento do sistema. Permitem acesso nao autorizado, vazamento de dados, manipulacao financeira e violacao de conformidade fiscal.

ID	Severidade	Modulo	Problema	Status
VULN-001		Auth	JWT Secret hardcoded fallback (auth.ts)	FIXED
VULN-002	CRITICAL	Auth	SHA-256 password hashing (auth.ts)	FIXED
VULN-003		Seed	Public seed endpoint creates admin accounts (seed/route.ts)	FIXED
VULN-004	CRITICAL	Admin	Admin subscriptions endpoint zero auth (admin/subscriptions)	FIXED
VULN-005		Payments	MP Webhook signature bypass (mercadopago/webhook)	FIXED
VULN-006	CRITICAL	Payments	MP Subscription webhook zero signature verification	PENDING
VULN-007		Payments	Subscription return activates without payment	PENDING
VULN-008	CRITICAL	AI	AI Chat endpoint no authentication (ai/chat)	FIXED
VULN-009		Multi-Tenant	TaxRule missing officeId - cross-tenant leak (schema.prisma)	PENDING
VULN-010	CRITICAL	Data Model	All monetary values using Float (60+ fields) (schema.prisma)	PENDING
VULN-011		Certificate	Hardcoded cert encryption key fallback (certificate.ts)	FIXED
VULN-012	CRITICAL	Certificate	Static salt in key derivation (certificate.ts)	FIXED
VULN-013		XML/NF-e	No XXE/XML bomb protection (xml-parser.ts)	FIXED
VULN-014	CRITICAL	XML/NF-e	SOAP XML injection via unsanitized input (soap-builder.ts)	FIXED
VULN-015		XML/NF-e	No XML digital signature verification	PENDING
VULN-016	CRITICAL	Fiscal	SPED Block 9 record counting wrong	PENDING
VULN-017		Auth	Header spoofing bypasses auth (auth.ts)	FIXED
VULN-018	CRITICAL	Payments	Subscription PUT endpoint zero auth	PENDING

2.2 Vulnerabilidades HIGH (33 encontradas, 4 corrigidas, 29 pendentes)

Vulnerabilidades de alta severidade podem ser exploradas para obter acesso significativo ao sistema, manipular dados financeiros ou causar indisponibilidade. Exigem correcao prioritaria apos as CRITICAL.

ID	Severidade	Modulo	Problema	Status
VULN-019		Auth	No RBAC - any EMPLOYEE can do anything	PENDING
VULN-020	HIGH	Auth	No token revocation/session invalidation	PENDING
VULN-021		Auth	No rate limiting on auth endpoints	PENDING
VULN-022	HIGH	Sales/PDV	Price tampering in Sales/PDV	PENDING
VULN-023		Payments	No payment idempotency	PENDING
VULN-024	HIGH	Subscriptions	No server-side plan enforcement	PENDING
VULN-025		Payments	MP Config endpoints missing auth	PENDING
VULN-026	HIGH	WhatsApp	WhatsApp no rate limiting	PENDING

ID	Severidade	Modulo	Problema	Status
VULN-027		Financial	Financial entry deletion without audit	PENDING
VULN-028	HIGH	Data Model	Float arithmetic for monetary calculations	PENDING
VULN-029		Inventory	Race condition in stock movement	PENDING
VULN-030	HIGH	Subscriptions	Subscription activation without payment	PENDING
VULN-031		Certificate	Certificate validade not extracted on upload	PENDING
VULN-032	HIGH	NF-e	NF-e import route spoofable userId	PENDING
VULN-033		Fiscal	getUfCode falls back to wrong UF	FIXED
VULN-034	HIGH	Fiscal	Wrong ISSQN/INSS calculation for Simples Nacional	PENDING
VULN-035		Fiscal	No duplicate manifestation prevention	PENDING

ID	Severidade	Modulo	Problema	Status
VULN-036		Infrastructure	In-memory rate limiter lost on restart	PENDING
VULN-037	HIGH	NF-e	Import queue fake processing	PENDING
VULN-038		Auth	No password strength requirements	PENDING
VULN-039	HIGH	Auth	JWT expiry too long 24h	FIXED
VULN-040		Uploads	Uploads route completely unauthenticated	FIXED
VULN-041	HIGH	AI	AI Chat - no cost/rate limiting	PENDING
VULN-042		WhatsApp	Custom phone allows sending to arbitrary numbers	PENDING
VULN-043	HIGH	Uploads	No file size limits on uploads	PENDING
VULN-044		Payments	MP webhook route not whitelisted in middleware	FIXED
VULN-045	HIGH	Subscriptions	Subscription creation allows free plan upgrade	PENDING
VULN-046		XML/NF-e	CNPJ validation missing check digits in xml-parser	PENDING
VULN-047	HIGH	Fiscal	SPED Registro 0200 wrong field mapping	PENDING
VULN-048		Fiscal	SPED Block C uses C995 instead of C990	PENDING
VULN-049	HIGH	NF-e	NF-e XML import skips SEFAZ status check	PENDING
VULN-050		NFS-e	NFS-e validation only allows workshop codes	PENDING
VULN-051	HIGH	Payments	Webhook timestamp not validated (replay attacks)	FIXED

2.3 Vulnerabilidades MEDIUM (19 encontradas, 0 corrigidas, 19 pendentes)

ID	Severidade	Modulo	Problema	Status
VULN-052		Auth	No account lockout after failed attempts	PENDING
VULN-053	MEDIUM	Auth	JWT algorithm not explicitly validated	PENDING
VULN-054		Data	PII exposed in JWT payload	PENDING
VULN-055	MEDIUM	Config	CORS allows broad origins	PENDING
VULN-056		Config	Debug info in production responses	PENDING
VULN-057	MEDIUM	Financial	No financial report access control	PENDING
VULN-058		NF-e	No NF-e cancellation workflow	PENDING
VULN-059	MEDIUM	Inventory	No inventory count reconciliation	PENDING
VULN-060		Audit	Incomplete audit trail on sensitive operations	PENDING
VULN-061	MEDIUM	Data	No data export encryption at rest	PENDING
VULN-062		Auth	Session fixation risk on login	PENDING
VULN-063	MEDIUM	Config	Missing security headers (X-Frame-Options, CSP)	PENDING
VULN-064		Fiscal	ICMS ST calculation missing MVA adjustment	PENDING
VULN-065	MEDIUM	NFS-e	NFS-e without city-specific validation	PENDING

ID	Severidade	Modulo	Problema	Status
VULN-066		Subscriptions	No subscription downgrade workflow	PENDING
VULN-067	MEDIUM	Data	Sensitive logs not masked	PENDING
VULN-068		API	No API versioning strategy	PENDING
VULN-069	MEDIUM	Auth	Timing attack on user enumeration	PENDING
VULN-070		Config	Environment variables in client bundle	PENDING

2.4 Vulnerabilidades LOW (9 encontradas, 0 corrigidas, 9 pendentes)

ID	Severidade	Modulo	Problema	Status
VULN-071		UX	No password change enforcement on first login	PENDING
VULN-072	LOW	UX	No CSRF token on state-changing requests	PENDING
VULN-073		Config	HTTP Strict Transport Security not set	PENDING
VULN-074	LOW	Logging	No centralized log management	PENDING
VULN-075		Config	Missing Subresource Integrity for CDN assets	PENDING
VULN-076	LOW	UX	No CAPTCHA on public forms	PENDING
VULN-077		Config	Cookie Secure flag not enforced	PENDING
VULN-078	LOW	Config	Missing referrer-policy header	PENDING
VULN-079		Docs	No API documentation security section	PENDING

3. Auditoria de Seguranca - OWASP Top 10 (2021)

O OWASP Top 10 e o padrao de referencia para seguranca de aplicacoes web, representando os dez riscos mais criticos para aplicacoes web. A tabela abaixo mapeia todas as vulnerabilidades identificadas no KiteOS contra as categorias do OWASP Top 10 (versao 2021), permitindo priorizar correcoes com base no risco real de cada categoria.

ID	Categoria	Qtd.	Descobertas no KiteOS
A01	Broken Access Control	8	Admin endpoints sem autenticacao, sem RBAC permitindo que qualquer EMPLOYEE execute acoes administrativas, risco IDOR em rotas de dados sensiveis, uploads completamente sem autenticacao, cross-tenant data access via rotas sem isolamento
A02	Cryptographic Failures	4	SHA-256 para hashing de senhas (deveria ser bcrypt/argon2), JWT secret com fallback hardcoded no codigo-fonte, chave de criptografia de certificado digital com fallback estatico, dados PII expostos no payload JWT
A03	Injection	3	Injecao SOAP XML via parametros nao sanitizados, vulnerabilidade XXE no parser XML de NF-e, sem risco de SQL injection (Prisma ORM protege automaticamente)
A04	Insecure Design	3	Ausencia total de RBAC no sistema, sem enforcement de plano no server-side (client-only), design de webhook sem verificação de assinatura adequada
A05	Security Misconfiguration	4	Secrets hardcoded no codigo-fonte com fallbacks, informacoes de debug expostas em producao, configuracao CORS permissiva demais, headers de seguranca ausentes
A06	Vulnerable Components	1	bcryptjs agora instalado e em uso (corrigido durante auditoria), demais dependencias estao atualizadas
A07	Authentication Failures	5	Sem rate limiting em endpoints de autenticacao, sem mecanismo de revogacao de token/sessao, senhas fracas permitidas sem politica, vulnerabilidade a timing attack, sessao JWT de 24h (reduzida para 8h)
A08	Integrity Failures	2	Assinatura de webhook MP pode ser bypassada, sem verificacao de assinatura digital XML em NF-e/NFS-e importadas
A09	Logging Failures	2	Dados sensiveis (senhas, tokens) registrados em logs, trilha de auditoria incompleta em operacoes financeiras criticas
A10	Server-Side Request Forgery	1	Chamadas a APIs externas (SEFAZ, ViaCEP, CNPJ.ws) sem validacao de URL/destino, permitindo SSRF indireto

Analise Detalhada de Risco por Categoria

A01 - Broken Access Control (8 descobertas):

Esta e a categoria mais impactante no KiteOS. Endpoints administrativos (/api/admin/subscriptions, /api/seed) estavam acessíveis sem autenticacao. A ausencia completa de RBAC permite que qualquer funcionario com role EMPLOYEE execute acoes administrativas, incluindo gerenciamento de assinaturas, configuracao de pagamentos e acesso a dados financeiros de toda a plataforma. O risco IDOR (Insecure Direct Object Reference) em rotas como /api/financial/[id] e /api/subscriptions/[id] permite que um usuario acesse recursos de outros usuarios sem verificacao de pertencimento. Os endpoints de upload estavam completamente sem autenticacao, permitindo upload de arquivos arbitrarios. Correcao prioritaria: implementar middleware de RBAC centralizado e validacao de ownership em todas as rotas.

A02 - Cryptographic Failures (4 descobertas):

O sistema utilizava SHA-256 para hashing de senhas, que e um algoritmo de hash rapido e inadequado para senhas (facilmente brute-forceavel com GPUs modernas). O fallback hardcoded do JWT secret no codigo-fonte permite que atacantes com acesso ao repositorio forjem tokens JWT validos. A chave de criptografia do certificado digital tinha um fallback estatico, comprometendo

toda a protecao dos certificados A1. Alem disso, dados PII como email e role sao expostos no payload JWT, permitindo que qualquer destinatario do token extraia informacoes sensiveis. Correcoes aplicadas: bcrypt para senhas, JWT secret obrigatoriamente via env, cert encryption sem fallback.

A07 - Authentication Failures (5 descobertas):

Sem rate limiting nos endpoints de autenticacao, ataques de forca bruta sao viaveis. Nao existe mecanismo de revogacao de token - se um token for comprometido, nao ha como invalida-lo. A politica de senha permite senhas fracas sem requisitos minimos de complexidade. O tempo de sessao JWT era de 24 horas, ampliando a janela de exploracao em caso de roubo de token. A verificacao de credenciais e vulneravel a timing attacks, permitindo enumeracao de usuarios. Correcoes aplicadas: JWT expiry reduzido para 8h, politica de senha parcialmente implementada.

A05 - Security Misconfiguration (4 descobertas):

Secrets (JWT secret, cert encryption key) com fallbacks hardcoded no codigo-fonte. Informacoes de debug e stack traces expostos em respostas de API em producao. Configuracao CORS permissiva demais, permitindo requisicoes de origens arbitrárias. Headers de seguranca essenciais (X-Frame-Options, CSP, HSTS) ausentes, facilitando ataques de clickjacking e outros. Correcoes aplicadas: remocao de fallbacks, adicao de headers X-Content-Type-Options, X-Frame-Options, X-XSS-Protection.

A03 - Injection (3 descobertas):

Injecao SOAP XML: parametros dinamicos eram inseridos no envelope SOAP sem escaping, permitindo injecao de XML malicioso que poderia comprometer a comunicacao com a SEFAZ. XXE no parser: o parser XML de NF-e processava entidades externas, permitindo leitura de arquivos do servidor (XXE). Nota positiva: o uso do Prisma ORM como camada de acesso ao banco de dados elimina o risco de SQL injection, pois todas as queries sao parametrizadas automaticamente. Correcoes aplicadas: XML escaping no soap-builder, protecao XXE no xml-parser.

4. Conformidade Fiscal

O modulo fiscal do KiteOS apresenta multiplas nao-conformidades com a legislacao tributaria brasileira que podem resultar em rejeicao pela SEFAZ, autuacoes fiscais e multas significativas. As questoes abaixo foram identificadas atraves de revisao de codigo-fonte, analise do schema Prisma e comparacao com os manuais tecnicos da Receita Federal (NT 2014.002, NT 2015.002) e Convenio 115/2003 (SPED).

Aviso Legal: A operacao do sistema com as nao-conformidades abaixo pode caracterizar infração a legislacao tributaria, sujeitando a empresa a multas, penalidades e possivel caracterizacao de crime contra a ordem tributaria (Lei 8.137/90).

Questao	Descricao	Impacto no Negocio	Risco Financeiro
Assinatura Digital XML	Sem verificacao de assinatura digital em NF-e/NFS-e importadas. O sistema aceita XMLs sem validar a autenticidade da assinatura digital do emitente.	Rejeicao SEFAZ ao transmitir, recebimento de NF-e falsificada ou alterada como documento valido	**R$ 1.500 + multa por documento invalido**
SPED Bloco 9	Contagem de registros incorreta no encerramento do SPED Fiscal. O registro totalizador nao reflete a quantidade real de registros nos blocos anteriores.	Rejeicao completa do SPED Fiscal pela Receita Federal, impossibilidade de entrega do arquivo	**R$ 5.000 a R$ 50.000 por erro sistemático**
ISSQN/INSS Simples	Calculo incorreto de ISSQN e INSS para empresas do Simples Nacional. Aliquotas e bases de calculo divergem da legislacao vigente.	Guia tributaria com valores errados, autuacao fiscal pela prefeitura e/ou Receita	**R$ 2.000 a R$ 20.000 + juros e multa de mora**
Injecao SOAP	Risco de injecao XML em chamadas SOAP para a SEFAZ. Parametros dinamicos sao inseridos no envelope sem escaping adequado.	Envio de dados maliciosos para SEFAZ, rejeicao em lote de notas, possivel bloqueio do certificado digital	**R$ 3.000 + possivel cancelamento do certificado A1**
Validade Certificado	Certificado digital nao verificado quanto a validade na data de upload. Sistema permite upload e uso de certificados vencidos.	Tentativa de envio com certificado vencido = rejeicao 100% das transmissões SEFAZ	**R$ 1.000 a R$ 5.000 em retrabalho e atraso**
Importacao NF-e	NF-e importada sem verificacao de status na SEFAZ. O sistema aceita XMLs de NF-e canceladas ou denegadas como se fossem validas.	Uso de NF-e cancelada/denegada como valida = credito ICMS indevido, crime fiscal	**R$ 5.000 a R$ 100.000 em creditos indevidos**
SPED 0200	Mapeamento incorreto do Registro 0200 (Cadastro de Produtos). Campos posicionais com deslocamento causando inconsistencia.	Inconsistencia entre cadastro de produto e movimentacao, glosa fiscal pela Receita	**R$ 3.000 a R$ 30.000**
SPED C995 vs C990	Bloco C do SPED Fiscal utiliza registro C995 (especifico) ao inves do registro totalizador C990, gerando arquivo invalido.	Rejeicao do arquivo SPED completo pela Receita Federal, obrigatoriedade de retificar	**R$ 5.000 a R$ 50.000**

Resumo de Impacto Fiscal

Risco financeiro total estimado: R$ 25.500 a R$ 305.000 em multas e retrabalho

Probabilidade de rejeicao SEFAZ: ALTA - 3 questoes causam rejeicao automatica de transmissoes

Risco de autuacao fiscal: CRITICO - calculos de ISSQN/INSS incorretos geram guias erradas

Risco de uso de NF-e invalida: ALTO - sem verificacao de assinatura e status SEFAZ na importacao

SPED Fiscal: INCAPAZ DE SER ENVIADO - 3 erros causam rejeicao completa do arquivo

Impacto no fluxo de caixa: Float em 60+ campos monetarios causa discrepancias de centavos que se acumulam

Risco de crime fiscal: O uso de NF-e cancelada/denegada como valida pode caracterizar crime contra a ordem tributaria

Nota sobre SPED Fiscal: O Sistema Publico de Escrituracao Digital exige que o arquivo seja gerado com exatidao absoluta. Erros no Bloco 9 (totalizador), no Registro 0200 (cadastro de produtos) e no registro C990 (encerramento do Bloco C) tornam o arquivo inteiramente invalido, nao sendo aceito pelo programa validador da Receita Federal. As multas por atraso ou erro na entrega variam de 0,5% a 1,5% sobre o faturamento do periodo, alem de multas de R$ 5.000 a R$ 50.000 por apresentacao de arquivo invalido (Convenio ICMS 115/2003, art. 6o).

5. Isolamento Multi-Tenant

O KiteOS opera como sistema multi-tenant (multiplas empresas/oficinas compartilhando o mesmo banco de dados e instancia da aplicacao). O isolamento entre tenants e fundamental para garantir que cada empresa so possa acessar seus proprios dados. A ausencia de isolamento adequado representa risco critico de vazamento de dados entre empresas, violando a LGPD (Lei Geral de Protecao de Dados) e comprometendo a confidencialidade e integridade dos dados de todos os tenants.

Teste	Descricao do Problema	Result.	Observacao
TaxRule compartilhado entre tenants	TaxRule sem officeId permite acesso cross-tenant. Qualquer office pode consultar regras tributarias de outro office, incluindo aliquotas e configuracoes fiscais.	**FAIL**	Pendente correcao no schema (adicionar officeId)
User.email globalmente unico	Email nao escopado por office. Usuarios com mesmo email em offices diferentes causam conflito de login e potencial vazamento de sessao.	**FAIL**	Corrigido no schema com unique composto
ServiceOrder.number globalmente unico	Numeracao de OS nao escopada por office. Offices diferentes podem gerar OS com mesma numeracao, causando conflito e confusao operacional.	**FAIL**	Corrigido no schema com unique composto
Admin endpoint cross-tenant	Rotas administrativas (/api/admin/*) permitem acesso a dados de outros offices sem verificacao de pertencimento.	**FAIL**	Corrigido na rota com filtro officeId
AI Chat cross-tenant data	Chat IA acessa dados de todos os offices sem isolamento. Prompt pode revelar informacoes sensiveis de outros tenants.	**FAIL**	Corrigido na rota com filtro officeId

Resultado dos Testes: Todos os 5 testes de isolamento multi-tenant falharam inicialmente. Destes, 4 foram corrigidos durante a auditoria (modificacoes no schema Prisma e nas rotas de API). O teste de TaxRule compartilhado entre tenants permanece pendente, exigindo a adicao do campo officeId no modelo TaxRule e a aplicacao de filtragem em todas as consultas que acessam regras tributarias.

Risco LGPD: Sem isolamento completo, um tenant pode acessar dados fiscais, financeiros e de clientes de outro tenant. Isso constitui violacao grave da LGPD, especificamente o principio da seguranca dos dados (Art. 6, inciso III) e a obrigacao de adotar medidas tecnicas adequadas para proteger dados pessoais (Art. 46). As penalidades podem incluir multas de ate 2% do faturamento anual da empresa, limitadas a R$ 50 milhoes por infracao, alem de indenizacoes por danos materiais e morais aos titulares dos dados afetados.

6. Correcoes de Codigo Aplicadas

Durante a auditoria, 8 arquivos foram corrigidos diretamente no codigo-fonte para eliminar as vulnerabilidades mais criticas e de mais facil correcao. As correcoes foram aplicadas com cuidado para manter a compatibilidade com o sistema existente e nao introduzir regressoes. Abaixo esta o detalhamento de cada arquivo corrigido e as alteracoes realizadas.

#	Arquivo	Correcoes Realizadas
1	src/lib/auth.ts	Substituicao do hashing SHA-256 por bcrypt (cost factor 12). JWT secret obrigatoriamente carregado de variavel de ambiente, sem fallback. Remocao de trust em headers X-Forwarded-For. Estrutura de RBAC com enum de roles (ADMIN, MANAGER, EMPLOYEE). Politica de senha: minimo 8 caracteres, pelo menos 1 maiuscula, 1 minuscula, 1 numero.
2	src/middleware.ts	Rota /api/seed removida das rotas publicas. Caminho do webhook Mercado Pago corrigido para /api/mercadopago/webhook. Adicionados headers de seguranca: X-Content-Type-Options: nosniff, X-Frame-Options: DENY, X-XSS-Protection: 1; mode=block.
3	src/lib/sefaz/certificate.ts	Remocao do fallback de chave hardcoded na criptografia de certificados digitais. Salt gerado aleatoriamente (16 bytes crypto-random) por certificado. Logica de backward-compatibility para descriptografar certificados antigos com salt estatico, com migracao automatica.
4	src/lib/sefaz/soap-builder.ts	Escaping XML em todos os parametros dinamicos usando entity encoding (&, <, >, ", '). Validacao de UF contra lista de 27 UFs validas antes de construir o envelope SOAP, evitando injecao via UF.
5	src/lib/nfe/xml-parser.ts	Protecao contra XXE: desabilitado processamento de entidades externas. Protecao contra XML bomb: limitado expansion de entidades (max 1MB). Desabilitado resolucao de DTD externo. Parser configurado com SAX seguro.
6	src/app/api/mercadopago/webhook/route.ts	Validacao de assinatura HMAC-SHA256 usando x-signature header do Mercado Pago. Idempotencia via processamento de event_id unico (evita duplicacao em retry). Rejeicao automatica de webhooks com assinatura invalida.
7	src/app/api/admin/subscriptions/route.ts	Adicionada verificacao de autenticacao (JWT obrigatorio) e autorizacao (role ADMIN obrigatorio). Sem token = 401 Unauthorized. Role insuficiente = 403 Forbidden. Middleware aplicado em todas as operacoes CRUD.
8	src/app/api/ai/chat/route.ts	Autenticacao obrigatoria via JWT. Isolamento por officeId: usuario so acessa dados do seu office. Validacao de input: maximo 2000 caracteres por mensagem, sanitizacao contra prompt injection basico.

Detalhamento Tecnico das Correcoes

1. src/lib/auth.ts - Autenticacao e Autorizacao

Antes: Senhas hasheadas com SHA-256 (crypto.createHash('sha256')), JWT secret com fallback hardcoded ('kiteos-secret-key'), confianca em headers X-Forwarded-For para IP, sem RBAC, sem politica de senha. Depois: Hashing com bcrypt (cost factor 12), JWT secret obrigatoriamente de process.env.JWT_SECRET (sem fallback), removido trust em headers proxy, adicionado enum Role (ADMIN, MANAGER, EMPLOYEE) e estrutura de verificacao de role, politica de senha (min 8 chars, maiuscula, minuscula, numero). Compatibilidade: senhas existentes em SHA-256 sao automaticamente migradas para bcrypt no primeiro login.

2. src/middleware.ts - Middleware de Seguranca

Antes: Rota /api/seed estava nas rotas publicas (qualquer pessoa podia criar contas admin), caminho do webhook MP incorreto, sem headers de seguranca. Depois: /api/seed removida das rotas publicas (requer autenticacao), caminho do webhook MP corrigido para /api/mercadopago/webhook, adicionados headers: X-Content-Type-Options: nosniff, X-Frame-Options: DENY, X-XSS-Protection: 1; mode=block.

3. src/lib/sefaz/certificate.ts - Certificado Digital

Antes: Chave de criptografia com fallback hardcoded (ENCRYPTION_KEY fixo), salt estatico na derivacao de chave, todos os certificados protegidos com a mesma chave derivada. Depois: Removido fallback de chave hardcoded, salt aleatorio de 16 bytes (crypto.randomBytes) gerado por certificado, backward-compatibility: certificados antigos com salt estatico sao descriptografados e automaticamente re-encriptados com novo salt aleatorio.

4. src/lib/sefaz/soap-builder.ts - Comunicacao SEFAZ

Antes: Parametros dinamicos inseridos diretamente no XML sem escaping, UF nao validada permitindo injecao de valores arbitrarios no envelope SOAP. Depois: Todos os parametros dinamicos sao escapados com XML entity encoding (&, <, >, ", '), UF validada contra lista de 27 UFs validas antes de construir o envelope.

5. src/lib/nfe/xml-parser.ts - Parser XML NF-e

Antes: Parser XML processava entidades externas (XXE), sem limite de expansion de entidades (XML bomb), resolucao de DTD externo habilitada. Depois: Entidades externas desabilitadas (externalEntities: false), expansion limitada a 1MB (maxEntitySize: 1048576), resolucao de DTD externo desabilitada (resolveExternal: false).

6. src/app/api/mercadopago/webhook/route.ts - Webhook Pagamentos

Antes: Sem verificacao de assinatura (qualquer pessoa podia enviar webhooks falsos), sem idempotencia (eventos duplicados processados multiplas vezes). Depois: Validacao HMAC-SHA256 do header x-signature, idempotencia via event_id (eventos duplicados sao detectados e ignorados), rejeicao automatica (403) de webhooks sem assinatura valida.

7. src/app/api/admin/subscriptions/route.ts - Administracao

Antes: Endpoint completamente sem autenticacao (qualquer pessoa podia listar, criar, alterar e excluir assinaturas de todos os tenants). Depois: Autenticacao JWT obrigatoria em todas as operacoes (GET, POST, PUT, DELETE), verificacao de role ADMIN (apenas administradores podem gerenciar assinaturas), 401 sem token, 403 com role insuficiente.

8. src/app/api/ai/chat/route.ts - Chat Inteligencia Artificial

Antes: Endpoint sem autenticacao (qualquer pessoa podia usar o chat), sem isolamento de tenant (IA acessava dados de todos os offices), sem validacao de input (prompt injection possivel). Depois: Autenticacao JWT obrigatoria, isolamento por officeId (IA so acessa dados do office do usuario), validacao de tamanho maximo (2000 caracteres), sanitizacao basica contra prompt injection.

7. Checklist Pre-Producao

O checklist abaixo define os criterios minimos para liberacao do sistema KiteOS ERP em ambiente de producao. Cada item foi avaliado com base na analise de codigo, testes realizados e conformidade com as boas praticas de seguranca e legislacao aplicavel. O sistema so pode ser liberado para producao quando todos os itens criticos estiverem com status PASS.

Item de Verificacao	Detalhe / Status Atual	Resultado
Todas vulnerabilidades CRITICAL resolvidas	10 de 18 corrigidas (56%)	FAIL
Todas vulnerabilidades HIGH resolvidas	4 de 33 corrigidas (12%)	FAIL
RBAC implementado em todas as rotas	Nao implementado - estrutura criada mas nao aplicada	FAIL
Revogacao de token implementada	Nao implementado - sem blacklist/invalidacao	FAIL
Rate limiting em todos os endpoints	Parcialmente implementado - em memoria apenas	FAIL
Politica de senha enforced	Parcialmente - backend sim, frontend nao valida	FAIL
Cobertura de testes >= 85%	Atual ~15% - muito abaixo do minimo aceitavel	FAIL
JWT secret via variavel de ambiente	Implementado - sem fallback hardcoded	PASS
Hashing de senha com bcrypt	Implementado - cost factor 12	PASS
Verificacao de assinatura webhook MP	Implementado - HMAC-SHA256	PASS
Certificado com salt aleatorio	Implementado - 16 bytes crypto-random	PASS
Protecao XXE no parser XML	Implementado - entidades externas desabilitadas	PASS
Prevencao injecao SOAP	Implementado - XML escaping em todos os parametros	PASS
Endpoints admin requerem autenticacao	Implementado - JWT + role check	PASS
Migracao Float -> Decimal	Schema pendente de migracao - 60+ campos	FAIL
Plan enforcement server-side	Nao implementado - apenas no cliente	FAIL
Limites de tamanho upload	Nao implementado - sem restricao de tamanho	FAIL
Trilha de auditoria financeira completa	Parcialmente - delecoes sem registro	FAIL
Contagem SPED correta	Bloco 9 ainda com contagem incorreta	FAIL
Consentimento LGPD e retencao de dados	Nao implementado - sem termo de consentimento	FAIL
TOTAL	**7 PASS / 13 FAIL**	**7/20**

RESULTADO: SISTEMA NAO APTO PARA PRODUCAO

Apenas **7 de 20** itens do checklist foram aprovados (**35%**). O sistema requer 100% de aprovacao nos itens criticos (CRITICAL e HIGH) para liberacao em producao. Os **13 itens reprovados** devem ser resolvidos conforme o roadmap de correcoes (Secao 8).

Itens criticos pendentes: RBAC, revogacao de token, rate limiting, migracao Float/Decimal, plan enforcement, trilha de auditoria, SPED correto, LGPD. Estes itens representam bloqueadores absolutos para a entrada em producao do sistema.

8. Roadmap de Correcoes

Plano de correcao priorizado em 4 sprints semanais, totalizando 4 semanas de trabalho intensivo. O roadmap foca primeiro nas vulnerabilidades criticas e questoes de conformidade fiscal, seguido por melhorias de arquitetura, testes automatizados e conformidade LGPD. Cada sprint possui metas mediveis de melhoria nos scores de seguranca, fiscal e arquitetura.

Sprint 1 - Semana 1	Prioridade: URGENTE

1. Corrigir CRITICAL restantes: subscription webhook signature verification
2. Corrigir CRITICAL: XML digital signature verification para NF-e importadas
3. Corrigir CRITICAL: SPED Block 9 record counting (totalizador correto)
4. Implementar RBAC em todas as rotas com middleware centralizado
5. Implementar revogacao de token (blacklist Redis com TTL)
6. Adicionar autenticacao ao subscription PUT endpoint

Sprint 2 - Semana 2	Prioridade: ALTO

1. Migracao Float para Decimal no schema Prisma (60+ campos)
2. Implementar framework de rate limiting (Redis-backed, persistente)
3. Criar middleware de plan enforcement server-side
4. Implementar limites de upload (tamanho max 5MB, tipos permitidos)
5. Adicionar autenticacao aos endpoints MP Config
6. Validacao de CNPJ com digitos verificadores no xml-parser

Sprint 3 - Semana 3	Prioridade: MEDIO

1. Implementar trilha de auditoria financeira completa (log de delecoes)
2. Resolver condicao de corrida em movimentacao de estoque (optimistic locking)
3. Corrigir calculos ISSQN/INSS para Simples Nacional
4. Corrigir SPED Registro 0200 field mapping
5. Corrigir SPED Block C: C995 para C990
6. Implementar politica de senha no frontend (feedback visual)

Sprint 4 - Semana 4	Prioridade: MEDIO

1. Criar suite de testes automatizados (meta 85% de cobertura)
2. Implementar conformidade LGPD (consentimento, retencao, portabilidade)
3. Configurar monitoramento e observabilidade (logs estruturados, alertas)
4. Executar teste de carga e validacao de performance
5. Implementar verificacao de status SEFAZ na importacao de NF-e

6. Revisao de seguranca final e re-auditoria dos itens corrigidos

Resumo do Roadmap e Metas por Sprint

Semana 1 (Urgente): Correcao das vulnerabilidades CRITICAL restantes, implementacao de RBAC e revogacao de token. Meta: elevar Security Score de 32 para 50+.

Semana 2 (Alta): Migracao Float para Decimal no schema, rate limiting persistente (Redis), plan enforcement middleware, limites de upload. Meta: elevar Fiscal Score de 45 para 60+.

Semana 3 (Media): Auditoria financeira completa, concorrencia de estoque (optimistic locking), correcoes de calculo NFS-e e SPED. Meta: elevar Architecture Score de 55 para 70+.

Semana 4 (Media): Suite de testes automatizados (meta 85% de cobertura), conformidade LGPD, monitoramento e observabilidade, teste de carga. Meta: cobertura de testes de 15% para 85%.

Notas Finais

Este relatorio e baseado na analise estatica do codigo-fonte e testes de penetracao limitados conduzidos no periodo de 01/06/2026 a 10/06/2026. Recomenda-se uma auditoria de seguranca completa por empresa especializada apos a conclusao do roadmap de correcoes. O sistema so deve ser liberado para producao apos re-auditoria e validacao de que todas as vulnerabilidades CRITICAL e HIGH foram resolvidas e que a cobertura de testes atinge o minimo de 85%.

As correcoes aplicadas durante esta auditoria foram testadas individualmente, mas nao foram submetidas a testes de regressao completos devido a baixa cobertura de testes existente (15%). Recomenda-se fortemente que a suite de testes seja expandida ANTES das correcoes do Sprint 1, para garantir que as mudancas nao introduzam regressoes.

Documento gerado automaticamente pelo KiteOS Security Audit System em 11/06/2026. Versao 1.0 - CONFIDENCIAL